

网络信息安全课程报告

# AI系统的"阿克琉斯之踵"

——针对学习型索引的对抗攻击与防御

主讲人：张娅萱

导师：韩京宇

计算机学院软件学院网络安全学院

2026年5月26日

SECURITY

# 目录

## TABLE OF CONTENTS

---

01 研究背景与动机

---

02 学习型索引基础知识

---

03 学习型索引的三大脆弱性

---

04 常见攻击面梳理

---

05 三层防御体系

---

06 攻击与防御措施对应关系总结

---

07 研究总结与未来方向

---

# 一、研究背景与动机

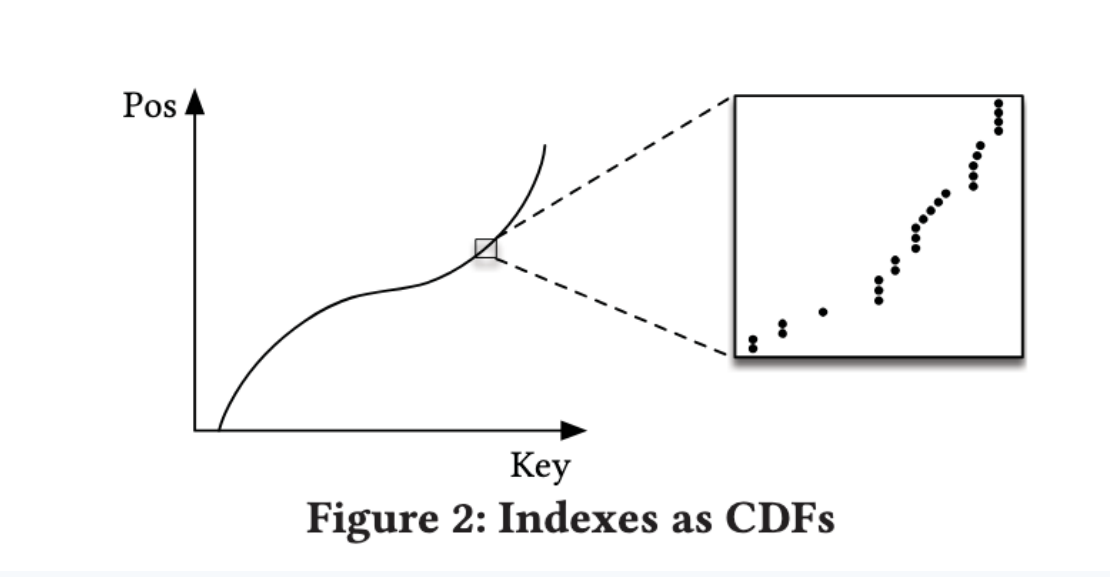
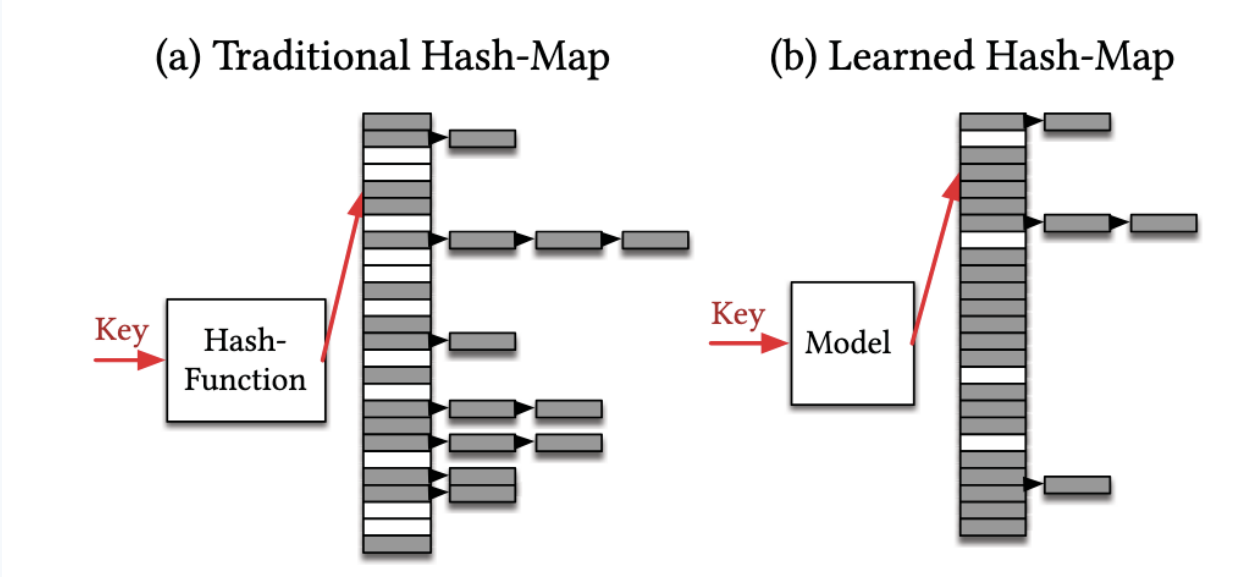
- 1

数据库系统是现代信息系统的核心基础设施，索引技术直接决定了数据查询的性能。传统索引结构（如B+树、哈希索引、位图索引）经过数十年发展已非常成熟，但它们都是通用数据结构，不了解数据本身的分布规律。
- 2

2018年，Google Brain团队提出：索引本质上是一个从查找键（Key）到存储位置（Position）的映射函数，这个函数完全可以用机器学习模型来学习。学习型索引（Learned Index）由此诞生，它使用神经网络或回归模型来拟合数据的累积分布函数（CDF），从而在极小的内存占用下实现比传统索引更快的查找速度。已在Google、Amazon、Meta等公司得到应用或实验性部署。
- 3

当索引从确定性数据结构变成统计学习模型时，它便继承了机器学习模型的一切脆弱性。对抗样本、数据投毒、模型窃取等经典AI安全问题，开始以新的形式出现在数据库内核中。
- 4

本次报告旨在从网络信息安全的视角，系统梳理学习型索引面临的攻击威胁，并探讨可行的防御方案。



## 二、学习型索引基础知识

**学习型索引的核心思想：**假设有N条有序数据记录，键的取值范围为K，第i条记录的位置可表示为  $i = F(\text{Key}) * N$ ，其中F是CDF。用机器学习模型M近似F，给定键x，用  $M(x) * N$  算出近似位置，在很小误差范围内二分查找可精确定位。

**与B+树本质区别：**B+树是"通用但不知数据长什么样"的结构，而学习型索引是"量身定做、知道数据分布"的模型。前者需要层层查找，后者一步到位给出预测。

学习型索引的典型代表：递归模型索引（RMI），由Google在2018年提出，是目前研究最广泛、应用最成熟的学习型索引结构。内存占用仅为传统索引的十分之一甚至更低，在读密集场景下查询延迟显著低于B+树。

**局限与安全问题：**写操作代价较高，模型需要重训练；对数据分布变化敏感，其安全性几乎没有在原始论文中被讨论过。

既然索引的核心变成了ML模型，所有针对ML模型的攻击后果可能比普通ML系统更严重，因为学习型索引直接服务于底层数据存取。

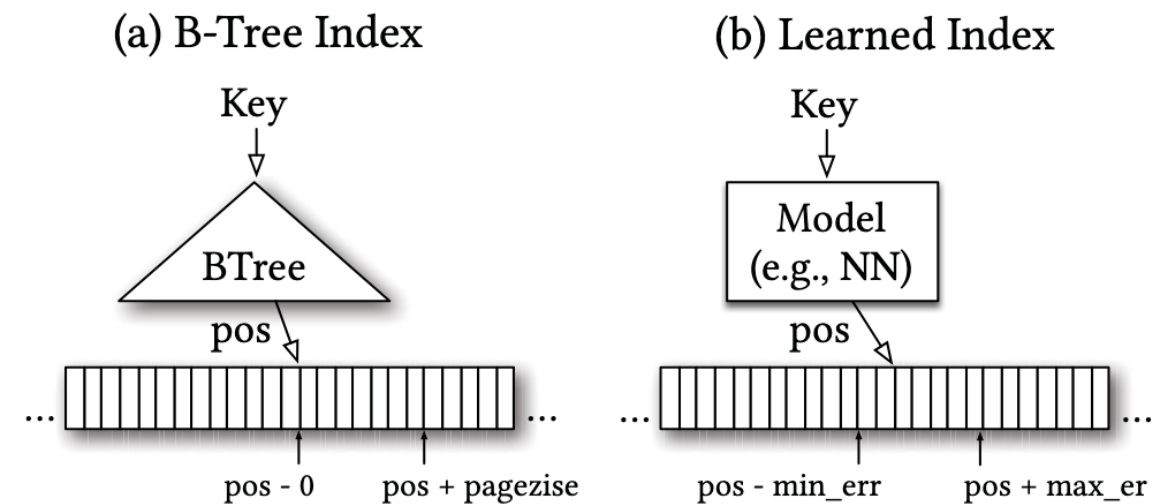


Figure 1: Why B-Trees are models

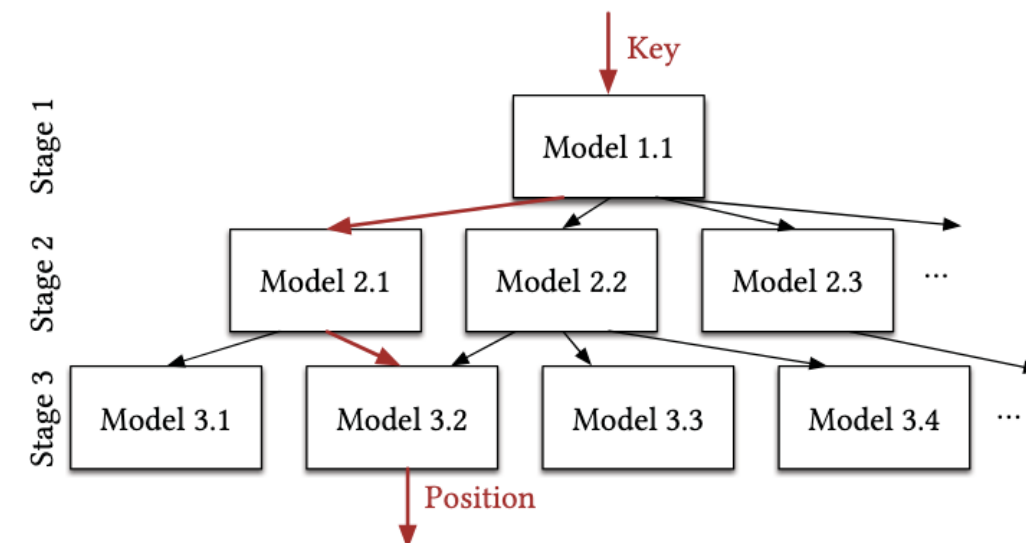


Figure 3: Staged models

## 三、学习型索引的三大脆弱性

### 脆弱性一

#### 模型函数的敏感性

学习型索引中使用的神经网络或复杂回归模型，天然具有对输入扰动的非线性和敏感性。输入键的微小改变（哪怕只是最低比特位翻转）可能导致输出预测位置发生剧烈跳变。

这与**对抗样本**产生的原理一致。

### 脆弱性三

#### 模型对训练数据的强依赖性

学习型索引的性能完全由训练数据决定。如果索引支持动态更新或从外部数据源学习，攻击者就可以通过注入恶意构造的键值对来污染训练集。

使模型学习到一个被篡改的数据分布，这种破坏是**持久性**的。

### 脆弱性二

#### 误差边界的可探测性

查询的响应时间直接与二分查找的区间长度正相关，攻击者可以通过测量不同键的响应时延，精确探知哪些键命中了模型拟合较差的区域。

从而获知模型的误差分布情况，甚至**反推出子模型的分段边界**。这给了攻击者黑盒条件下进行攻击的完美反馈信号。

#### 结论

这三大脆弱性并非偶然的实现缺陷，而是**"用模型替代数据结构"**这一技术路线在原理层面不可避免的安全代价。

任何将学习型索引用于生产系统的尝试，都必须正视并应对这些风险。

## 四、攻击面梳理：攻击者视角

从攻击者的角度，将学习型索引的生命周期分解为三个主要环节，每个环节都对应一个攻击面：

| 攻击面一：推理查询接口                                                                                                                    | 攻击面二：训练数据管道                                                                                                              | 攻击面三：计时侧信道                                                                                                    |
|--------------------------------------------------------------------------------------------------------------------------------|--------------------------------------------------------------------------------------------------------------------------|---------------------------------------------------------------------------------------------------------------|
| <p>系统上线后对用户暴露的查询入口。</p> <p>攻击者可以向接口发送精心构造的恶意查询键，在不攻击训练数据的情况下直接对线上服务造成破坏。</p> <p><b>对应攻击类型：</b><br/>对抗性查询攻击（Evasion Attack）</p> | <p>如果学习型索引支持在线增量学习、定期重训练或从不完全可信的数据源合并数据，攻击者就有机会向训练集注入毒化样本，从而污染模型。</p> <p><b>对应攻击类型：</b><br/>数据投毒攻击（Poisoning Attack）</p> | <p>即使攻击者无法直接接触模型参数，也可以通过观测查询的响应时间、资源消耗甚至错误日志等侧信道信息，推断出模型内部参数或底层数据分布。</p> <p><b>对应攻击类型：</b><br/>模型窃取与侧信道攻击</p> |

**CIA安全威胁三角：**这三种攻击分别破坏系统的**可用性**（对抗性查询）、**完整性**（数据投毒）与**机密性**（模型窃取），形成完整的安全威胁三角。



# 攻击一：对抗性查询攻击

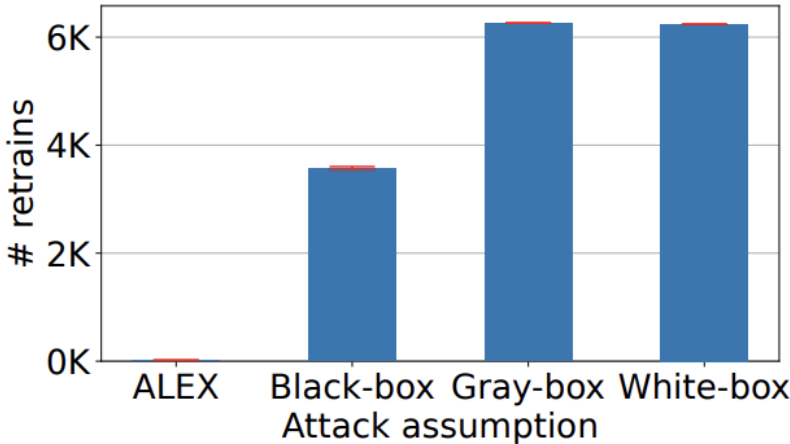
- 1

**攻击目标：**构造恶意查询键，使得学习型索引的预测位置严重偏离真实位置，从而迫使系统在小范围内进行极大范围的二分查找，造成单次查询的CPU资源和时延急剧增加，最终实现拒绝服务。
- 2

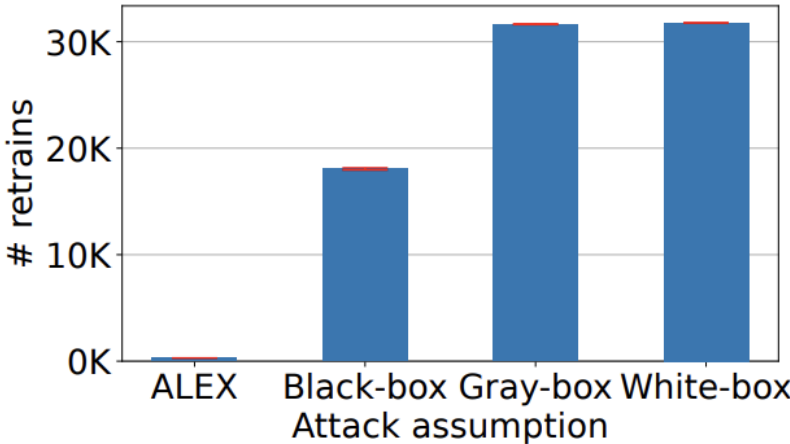
**白盒攻击方法：**假设攻击者已知模型的结构和参数（如通过前期的模型窃取获得），可以使用基于梯度优化的方法。从一个正常键x出发，沿梯度方向添加一个极小的扰动 $\delta$ ，使得损失函数  $L = -(\text{pred}(x+\delta) - \text{true\_position})^2$  最大化，即使预测位置尽可能远离真实位置。
- 3

**黑盒攻击方法：**在更实际的场景中，攻击者只有查询权限。此时可以通过反复发送不同的键，测量响应时延，以时延为适应度函数，使用黑盒优化算法（如遗传算法、贝叶斯优化等）来逐步搜索出"最慢的查询键"。
- 4

**攻击可行性：**所需查询次数在数百到数千次量级即可收敛到一个有效对抗样本，在真实系统中完全可行，且查询请求本身符合语法规范，**难以被传统防火墙拦截。**



(a) Read-heavy Workload.



(b) Write-heavy Workload.



# 攻击二：数据投毒攻击

- 1

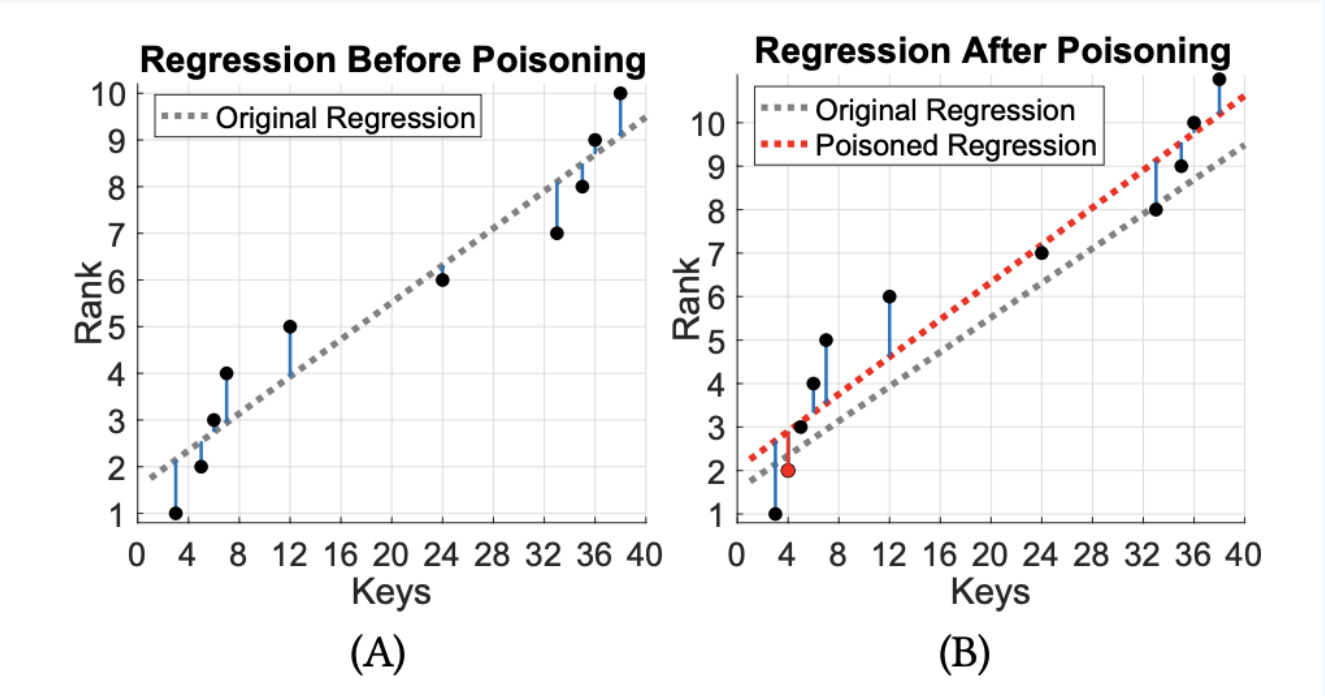
**攻击场景：**学习型索引需要进行初始训练，并且在数据分布发生显著变化时可能需要重训练或增量更新。如果攻击者能够在这阶段向训练数据中注入少量恶意键值对，就可以污染模型的记忆，使其从根本上发生偏差。
- 2

**攻击方法：**攻击者精心挑选模型拟合能力薄弱的区域（如数据分布的拐点、密集区边缘、两个子模型分界处）插入毒化数据。例如，在一个原本光滑的线性区域中插入一组呈现"Z"字形微扰动的数据点，这会迫使回归模型的斜率发生显著改变。
- 3

**攻击效果：****一次投毒，永久破坏。**凡是被毒数据影响到的键值区间，后续所有正常用户的查询都会变慢。这种攻击并不需要攻击者持续在线，毒化效应会随模型训练固化下来，极具隐蔽性和持续性。
- 4

**难度与可行性：**所需毒化样本占比通常只需总训练数据的 **1%~5%** 即可产生明显效果。在数据来源不完全可信或系统缺乏严格数据校验的场合，投毒攻击非常现实。

**核心威胁：**数据投毒从训练源头破坏索引模型，不需要持续在线攻击，毒化效果永久固化，隐蔽性极高。





# 攻击三：模型窃取与侧信道攻击

- 1

**攻击目标：**不直接破坏系统的可用性或完整性，而是窃取机密信息，包括模型参数、模型结构、乃至底层训练数据的分布特征。
- 2

**侧信道泄露机制：**学习型索引的查询响应时间直接暴露了二分查找区间的大小，而区间大小又由模型的预测误差决定。计时信息成为一条泄露内部状态的侧信道。攻击者通过发送一系列探测查询，精确测量每次查询的时延，就可以构建出一张**"键-预测误差"映射热力图**。
- 3

**基于热力图的信息反推：**从误差热力图上，可以进一步推断出子模型的边界位置（因为边界处预测误差通常较大）、模型的拟合能力分布（哪些区域欠拟合），以及底层数据的密度分布。这些信息可能直接构成商业机密或个人隐私泄露。
- 4

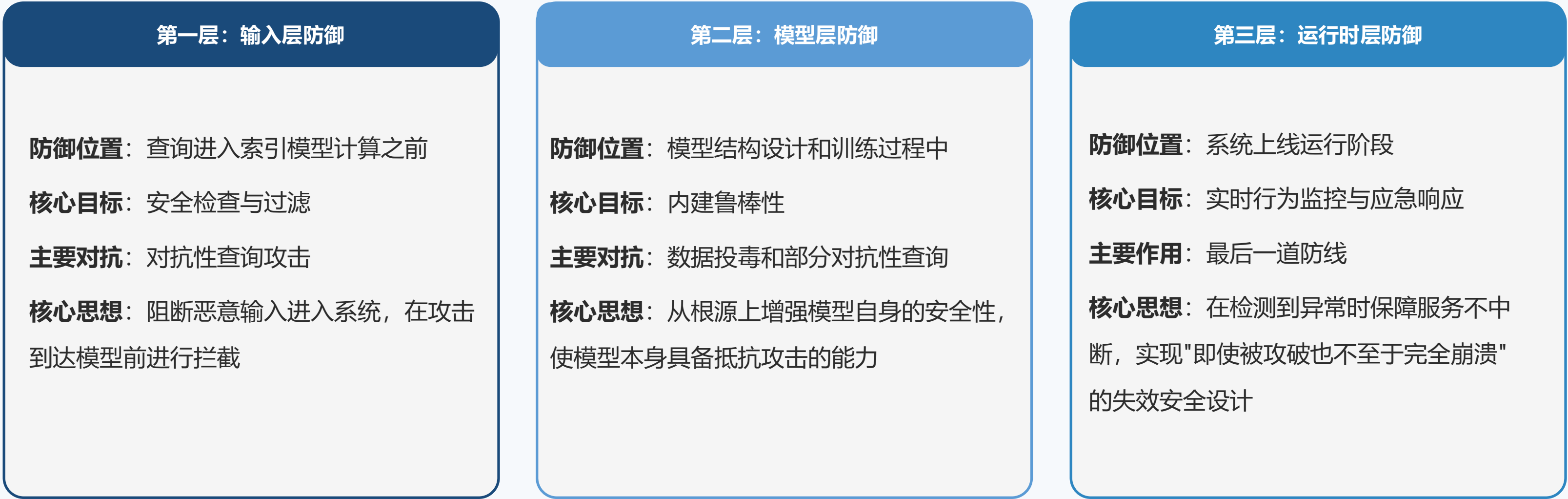
**模型窃取攻击：**攻击者利用探测获得的大量"键-预测位置"对，作为监督学习的训练数据，训练一个功能近似于原索引模型的替代模型。一旦替代模型训练成功，可用于：构造更强大的白盒对抗样本；非法复制受知识产权保护的索引模型；分析替代模型挖掘更多原始数据分布秘密。

隐蔽性：只产生正常查询流量，没有异常数据写入，没有越权操作，**仅靠计时分析就能完成**，传统的安全审计机制极难察觉。

**核心威胁：**侧信道攻击利用查询响应时间泄露模型内部状态，模型窃取则在此基础上进一步复制整个索引模型，两者结合形成完整的机密性破坏链。

## 五、防御策略框架：纵深防御的三层体系

单一防御措施无法应对多样化、多层级的攻击，必须构建纵深防御体系：



**三层协同：**输入层拦截大部分已知恶意模式；模型层降低攻击成功率并减小破坏程度；运行时层提供兜底保护。纵深防御是应对复杂安全威胁的核心思想。

# 第一层防御：输入清洗与异常检测

措施一

## 查询键值域合法性校验

维护训练数据的键值范围以及分布密度概况，对明显超出值域范围或落入零密度极端离群区域的查询键直接拒绝，返回错误码，避免模型对无意义输入进行预测。

措施二

## 查询分布实时监控

在输入端维护一个滑动时间窗口内的键值分布统计，当检测到某个客户端发送的键值分布与历史正常分布存在显著偏离（如KL散度突然增大）时，标记为可疑行为并触发限流或验证码机制。

措施三

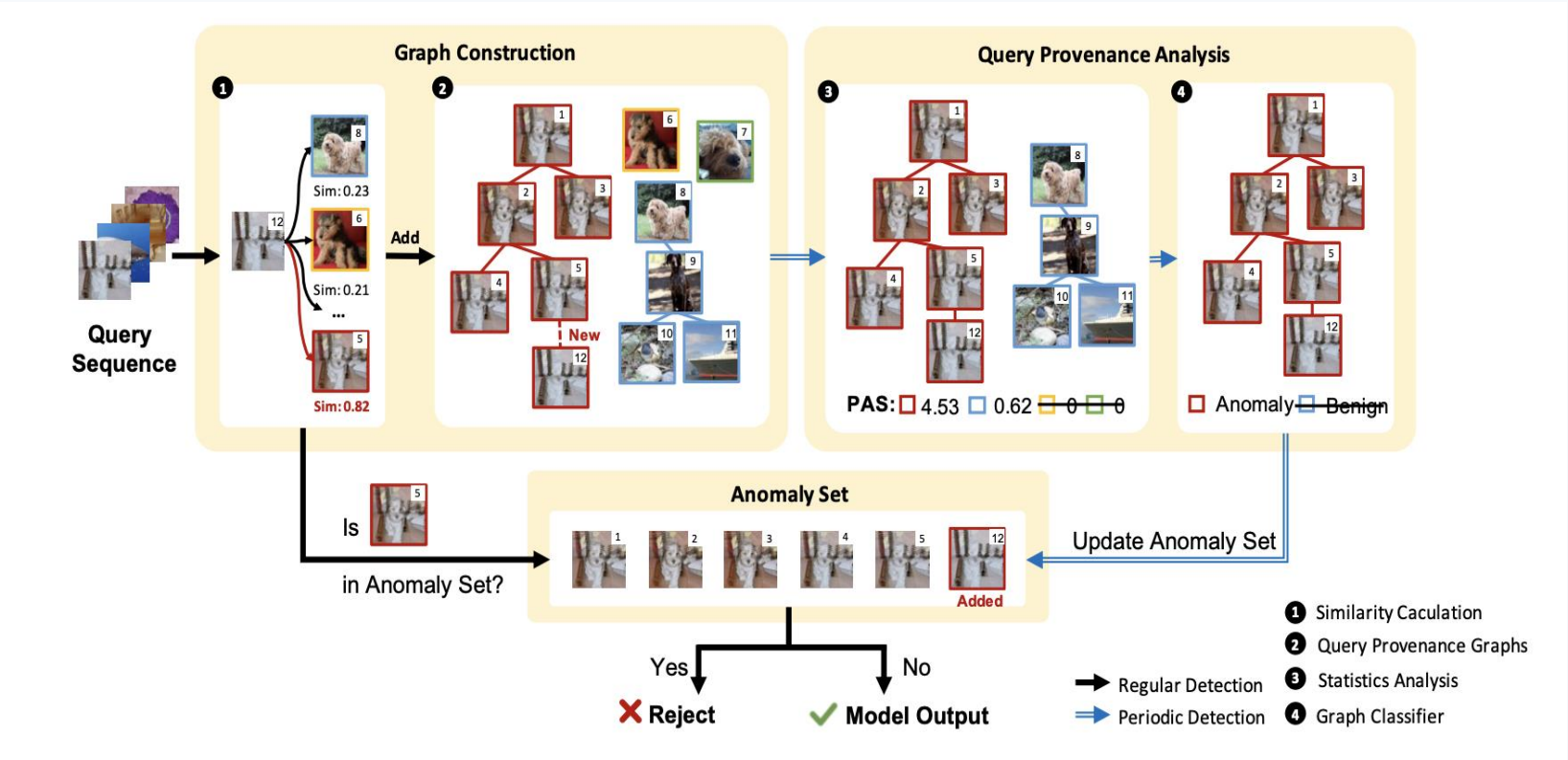
## 恶意查询模式识别

基于已知的攻击样本特征，训练一个轻量级的在线分类器（如决策树、小型逻辑回归模型），对每个查询键提取简单特征（如数值范围、与上一次查询的差异等），判断其是否具有对抗性查询的潜在特征。由于该分类器极轻量，可在查询路径上以极低开销运行。

措施四

## 频率限制与客户端信誉机制

对单客户端实施严格的查询速率限制（Rate Limiting），并对频繁触发慢查询的客户端降低信誉分，信誉低于阈值的客户端请求被降级处理或暂时屏蔽。这能有效遏制需要大量探测的黑盒攻击。



# 第二层防御：鲁棒学习型索引设计

措施一

对抗训练 (Adversarial Training)

在模型训练阶段，使用对抗样本生成方法（如针对当前模型状态的白盒梯度攻击）生成一批恶意键值对，将这些对抗样本连同其正确的存储位置标签一起加入训练集，强制模型学习在面对抗扰动时仍输出正确或低误差的位置预测

措施三

强制单调性结构

放弃使用普通神经网络，转而采用数学上保证单调性的模型结构（如分段线性样条RadixSpline、单调神经网络等）。单调性意味着输入键增大时预测位置也一定增大，从根本上限制了攻击者能够操纵预测结果偏离真实值的幅度。

措施二

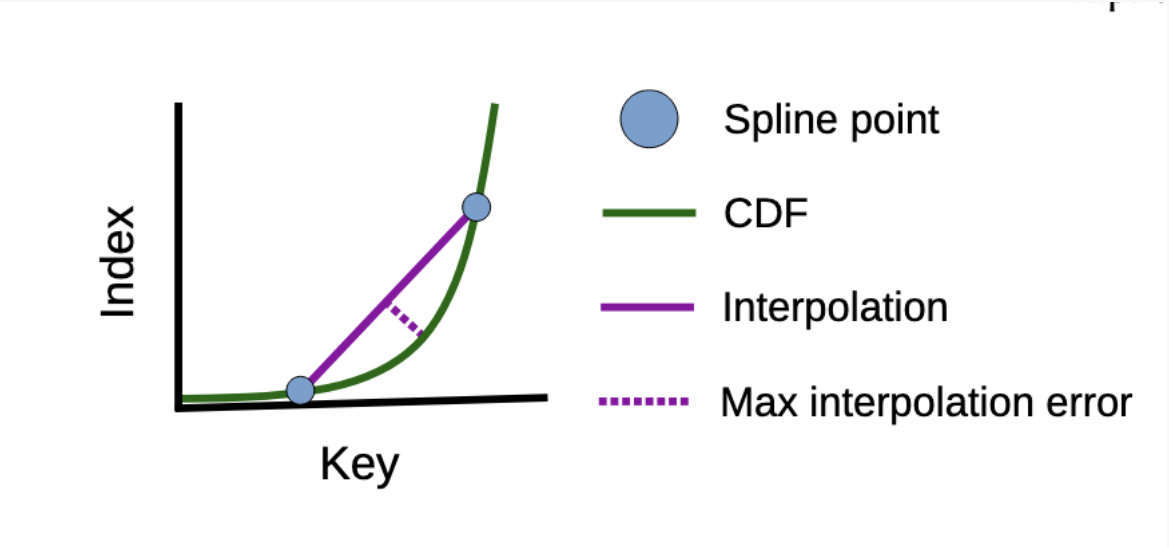
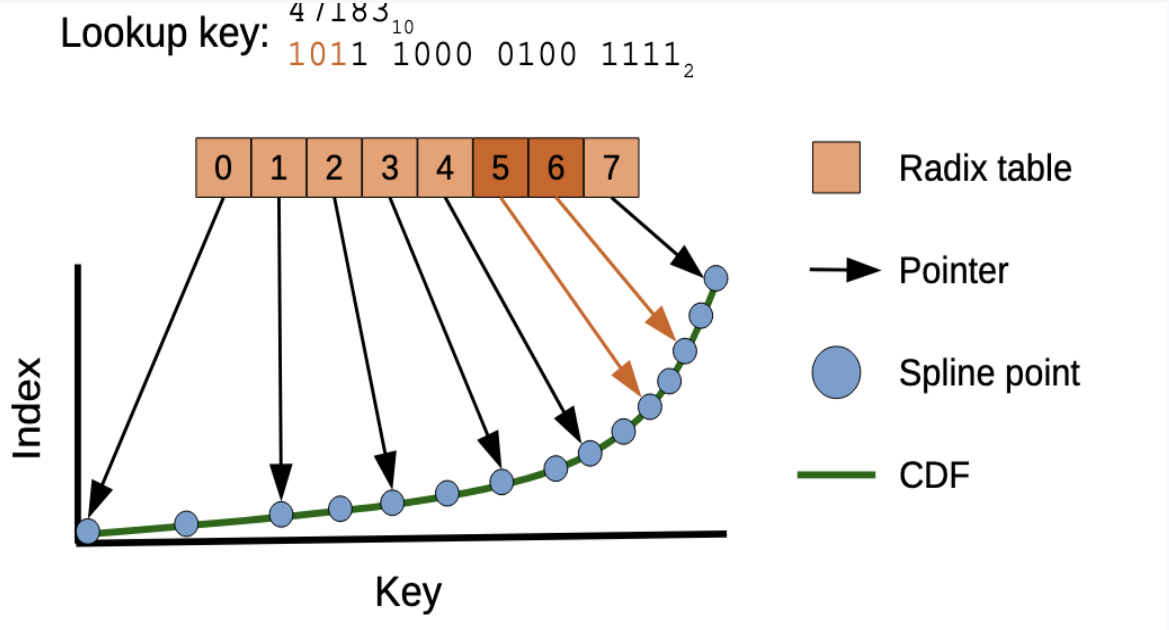
集成索引 (Ensemble Indexing)

同时训练多个不同初始化、不同结构或不同数据子集上训练的索引模型。对于每个查询键，所有模型分别给出预测位置，最终取它们的中位数或加权平均作为系统预测。

措施四

训练数据完整性保护

对训练数据进行严格的完整性校验与来源追踪，使用数字签名或哈希链确保数据未被篡改；对增量更新的数据实施脏数据过滤，拒绝统计特征明显异常的批次插入。。



# 第三层防御：运行时监控与弹性降级

措施一

实时性能指标监控

在查询执行引擎内部埋入轻量级探针，实时统计每个查询的实际二分查找比较次数、查询延迟、以及各子模型的平均误差。将这些指标以时间序列形式上报监控系统。

措施二

异常阈值告警

设定安全基线：正常状态下99.9%的查询二分比较次数应低于阈值T（例如T=128次）。当系统中超过一定比例（如5%）的查询比较次数连续多个时间窗口超过T时，判定为可能遭受攻击或模型退化，触发告警。

措施三

弹性降级机制

当告警触发时，系统自动启动降级流程：将查询流量从学习型索引无缝切换到一个预先维护好的、轻量级的传统索引（如B+树或哈希索引）上。传统索引不受对抗样本影响，性能稳定可预期。切换过程在秒级内完成，对上层应用仅表现为查询延迟的轻微抖动，不造成服务中断。

措施四

事后分析与恢复

安全事件发生后，可利用监控系统保存的慢查询日志和异常键样本，对攻击进行溯源分析，修复或重训练受影响的索引模型，待验证安全性后，再将流量切回学习型索引。



## 六、三大攻击与防御措施对应关系总结

| 攻击类型       | 攻击目标  | 主要危害          | 对应防御层            | 具体防御手段                         |
|------------|-------|---------------|------------------|--------------------------------|
| 对抗性查询攻击    | 推理阶段  | 拒绝服务、可用性破坏    | 输入层 + 模型层 + 运行时层 | 输入过滤、异常检测、对抗训练、集成索引、弹性降级       |
| 数据投毒攻击     | 训练阶段  | 完整性破坏、持久化性能下降 | 模型层防御            | 训练数据校验、鲁棒训练、后门检测技术             |
| 模型窃取与侧信道攻击 | 推理侧信道 | 机密性泄露、知识产权损失  | 输入层 + 模型层        | 频率限制、响应时间混淆、模型结构保护（如添加随机延迟、量化） |

**核心结论：**没有一劳永逸的单一解，纵深防御是应对复杂安全威胁的核心思想。三种攻击分别对应CIA安全三角（可用性、完整性、机密性），必须构建多层协同的防御体系。

## 七、研究总结与未来方向

### 研究总结

- 学习型索引用机器学习模型替代传统数据结构，在获得内存和性能优势的同时，也继承了ML模型的**全部安全脆弱性**
- 对抗性查询攻击能够以极低成本造成严重的拒绝服务，且流量在应用层完全合法，**检测困难**
- 数据投毒攻击可以从训练源头污染索引，隐蔽持久，其后门形式**尤其危险**
- 侧信道与模型窃取攻击使攻击者能在不被察觉的情况下获取系统内部机密，进一步加剧安全风险
- 通过"输入过滤-鲁棒模型-运行时降级"**三层纵深防御**，可以在发挥学习型索引性能优势的同时，将其安全风险控制在可接受范围内

### 未来研究方向

- **可验证学习型索引**：利用形式化验证方法，在数学上证明索引模型的误差上界在任何输入下均不可突破，从根本上杜绝对抗性查询的可能
- **差分隐私索引训练**：在训练过程中引入差分隐私机制，既能防御数据投毒造成的原始数据泄露，也能保护底层数据隐私
- **面向联邦学习场景的安全学习型索引**：在多个参与方联合训练全局索引模型时，如何防御恶意参与者的投毒与推理攻击
- **自动化攻击与防御评估基准**：构建标准化的学习型索引安全测试平台，推动社区对索引安全性的系统化研究



# 感谢聆听

THANK YOU FOR YOUR ATTENTION

---

## Q & A

请各位老师和同学批评指正！